Viney Washington

Unit 6 Assignment Submission

Exercise 1: Differentiate the phases of a cyberattack.

1. **Differentiate Between the Specific Phases of the Attack from Initial Compromise to Data Exfiltration**

BioGenX is a midsized biotechnology firm that specializes in gene therapy research. Unfortunately, their system was compromised due to gaps in cybersecurity awareness and monitoring. There was a baseline security standard and some employee training in place, but security controls were not consistently maintained. Their most common risks included phishing campaigns, stolen credentials, and unauthorized data transmission. Even though these events resulted in a data breach, the incident can be separated into structured cyberattack phases using the Cyber Kill Chain model. This model identifies and helps prevent cyber intrusion activity (Lockheed Martin, n.d.). By identifying the stages of an intrusion, defenders can better detect and stop attacks at different points in the lifecycle. Using the phased model, the BioGenX attack can be differentiated as follows:

In the Reconnaissance phase, the attackers researched BioGenX researchers and their professional details. This allows attackers the ability to identify their entry point and choose the right targets before launching the attack. Its main tactics are harvesting email addresses, identifying employees on social media, collecting press releases, and discovering internet-facing servers (Lockheed Martin, n.d.). The phishing emails were designed to appear as legitimate sources. That level of customization shows the attackers gathered background information before launching the attack. This matches the reconnaissance stage where threat actors study their target first and prepare targeting information before weapon use.

In the weaponization phase, the attackers prepared the malicious tool that would be used in the attack. There are several tactics used in this phase such as obtaining sensitive information through private or public channels, file-based exploits, backdoor implants, designating a specific mission ID, completing the backdoor, and weaponizing the payload (Lockheed Martin, n.d.). To simplify this phase, the attacker created credential-stealing malware and combined it with a malicious link. This step happens before the message is sent and prepares the payload so it will work once the victim interacts with it.

In the delivery phase, the attacker sends the malicious payload to the target. Delivery is defined as “the transmission of the weapon to the targeted environment” (Lockheed Martin, n.d.). At BioGenX, this happened through a spear phishing email sent directly to a researcher. The message looked like it came from a trusted academic journal, which made it more believable and increased the chance it would be opened. This phase is different from weaponization because the tool is already built and transmitted to the victim.

The exploitation phase occurs when the researcher clicked the malicious link and the malware executed. It comes in various forms such as software vulnerabilities, zero-day exploits, adversary-triggered exploits, and victim-triggered exploits (Lockheed Martin, n.d.). This is the point where the initial compromise happened. The system was not broken into through a technical exploit but through user interaction, which shows how spear phishing can trigger execution without directly attacking software defenses.

In the installation phase, the attacker establishes continued access. It is described as the stage that "installs malware on the victim asset" (Lockheed Martin, n.d.). In this incident, the malware captured valid user credentials, which allowed the attacker to return and move through the network without needing obvious backdoor software. This phase creates persistence so access continues after the first compromise.

In the command-and-control phase, attackers maintain communication with compromised systems. This is established by opening a two-way communication channel. Common C2 channels operate over web, DNS, and email protocols, and the C2 infrastructure may be adversary owned (Lockheed Martin, n.d.). The BioGenX case explains that the stolen data was transmitted out disguised as legitimate scientific communication traffic. That shows the attacker was maintaining controlled and hidden communication channels to avoid detection while operating inside the network.

The final phase is actions on objectives. It is the final stage where the attacker achieves the mission goal (Lockheed Martin, n.d.). In the BioGenX breach, the attackers slowly exfiltrated research data and unencrypted patient information over several weeks without being detected. This confirms the objective phase was successful because sensitive data was removed from the environment.

Overall, the BioGenX breach clearly followed the Cyber Kill Chain stages from reconnaissance through actions on objectives. The attack started with targeted research and spear phishing, then moved through malware execution, credential capture, internal movement, command-and-control communication, and finally long-term data exfiltration. Breaking the incident into phases makes it easier to understand how the attack progressed step by step instead of viewing it as a single event.

2. Describe the Progression of the Spear Phishing Attack and Map Subsequent Actions to Cyber Kill Chain Phases

BioGenX did not experience spear phishing attack as a single step. It progressed through multiple structured phases that align with the Cyber Kill Chain model. Each stage shows a different attacker objective, starting with target research and ending with data exfiltration. Analyzing each attacking phases make it easier to understand how a single phishing email turned into a larger network breach. It helps identify how credential theft, lateral movement, and hidden data transfers are linked, instead of separate events. Mapping each step to a The Kill Chain phase helps to justify how the intrusion progressed and supports a structured attack analysis (Lockheed Martine, n.d).

The progression started with reconnaissance, where the attackers researched BioGenX researchers and built targeted emails that appeared to come from a reputable academic journal. The reconnaissance phase includes “research, identification and selection of targets, often represented as crawling Internet websites such as conference proceedings and mailing lists for email addresses, social relationships, or information on specific technologies in use” (Lockheed Martin, n.d.). This confirms that the phishing emails were customized and sent to specific researchers instead of being randomly distributed.

After target research, the attack moved into weaponization, where the attackers prepared credential-stealing malware and paired it with a malicious link. This phase ensures that the information was successful delivered to the victim. The framework states that “weaponization couples remote access malware with an exploit into a deliverable payload” (Lockheed Martin, n.d.). This confirms that the malware and link were prepared before the email was sent. The next step was delivery, when the spear phishing email was transmitted to the researcher. The model defines this stage by stating that “delivery is the transmission of the weapon to the targeted environment” (Lockheed Martin, n.d.), which in this incident occurred through a trusted-looking academic email message

With valid credentials available, the attacker performed lateral movement by accessing shared internal systems and locating a misconfigured legacy file server containing research and unencrypted patient data. This shows expansion after initial compromise, where attackers move from the first infected system to higher-value resources. The next mapped stage was command and control, which the framework defines by explaining that it “establishes a channel for remote manipulation of the victim” (Lockheed Martin, n.d.). In the case study, outbound data transfers were disguised as legitimate scientific communication traffic, which shows the attacker maintained hidden control channels while operating inside the network.

The final stage was actions on objectives, where the attacker completed the mission goal. The model states that “actions on objectives are the final stage where the attacker achieves the mission goal” (Lockheed Martin, n.d.). At BioGenX, this occurred when research and patient data were slowly exfiltrated over several weeks. This confirms that the spear phishing email was only the entry point, and the real breach developed through multiple connected Kill Chain stages, including payload preparation, exploitation, lateral movement, command-and-control activity, and planned data exfiltration.

Exercise 2: Discriminate between viable and unviable phases of attack.

1. Vulnerabilities Exploited in the BioGenX Data Breach

The BioGenX breach identifies the attacker’s primary vulnerability exploited as human factors. The initial compromise was from a spear phishing link sent to a researcher from a trusted academic journal. Even though the organization had moderate cybersecurity awareness and regular training, the targeted nature of the message still succeeded. This is a strong indication that awareness training is not enough to maintain the integrity, confidentiality, and availability within the organization. When attackers customize messages to match employee roles and expectations, this creates a viable attack path. Social engineering attacks are effective when

focused on human trust and behavior instead of technical weakness. User behavior plays a central role in security outcomes and risk exposure. Therefore, organizations that employ secure protocols and procedures, use cryptography, and have secure hardware and software are equally susceptible to social engineering attacks as those organizations where technical and computer security is lacking (Schneier, 2000). This supports that employee susceptibility to targeted phishing directly exploited vulnerability.

Legacy systems and misconfiguration were another major vulnerability in the BioGenX environment. The attackers were able to move laterally to locate a misconfigured file server that was part of older infrastructure. This misconfigured file server was never regularly audited or updated. Older systems often fall outside normal security review cycles and may keep outdated permissions or insecure configurations. In the BioGenX case, the legacy collaboration server stored sensitive research and patient data, which increased the damage once accessed by attackers. Legacy infrastructure becomes a risk when security maintenance is reduced due to budget cuts or operational pressure. Systems like this often remain in production longer than expected and accumulate configuration weaknesses over time. Legacy platforms are dangerous because "legacy systems often lack modern security controls and are harder to patch and protect," which increases exposure when they remain connected to active networks (ModLogix, 2025). Modern cybersecurity frameworks emphasize continuous risk reduction and control improvement across environments, which shows that outdated and misconfigured systems must be reviewed regularly instead of ignored.

Inadequate data handling practices were exploited in this breach. The storage of unencrypted sensitive information on a shared system was exploited. The case specifically states that early-stage research data and unencrypted patient information were stored on the collaboration server. When sensitive data is not encrypted, unauthorized access immediately turns into usable exposure. Proper data protection requires encryption and tighter segmentation for regulated and research data. Storing high-value information in shared locations increases concentration risk and makes lateral movement more damaging. Security frameworks stress that protective safeguards should reduce the impact of compromise, not just try to prevent entry. The NIST framework describes cybersecurity outcomes as including safeguards that support "the ability to prevent or mitigate adverse cybersecurity events" (NIST, 2024). BioGenX stored sensitive data without encryption on a shared resource, and poor data protection controls were clearly a vulnerability that attackers exploited.

Network monitoring deficiencies were another key weakness that allowed the BioGenX breach to continue for an extended period without detection. Data exfiltration occurred slowly over several weeks and went unnoticed since sophisticated intrusion detection systems were not in place. This shows an attacker stayed active inside the network and removed data without triggering alerts or investigation. Slow and disguised data transfer is a known attacker technique used to avoid detection thresholds and blend in with normal traffic patterns. Without strong monitoring, log review, and event correlation, malicious behavior can appear similar to routine user activity. Effective security operations depend on continuous monitoring, and unusual authentication patterns, outbound traffic spikes, and access behavior often appear in system logs first. Network defenders should review and monitor logs for unusual or suspicious activity

(CISA, 2022). BioGenX lacked strong detection and monitoring controls, and the attacker was able to maintain access and remove sensitive data without being flagged, which confirms that monitoring gaps were directly exploited.

Overall, the BioGenX breach shows that the attacker did not rely on a single weakness but instead exploited multiple vulnerabilities across people, systems, and monitoring controls. Human behavior, outdated infrastructure, poor data protection, and weak detection together created the conditions for a successful breach. These exploited vulnerabilities confirm that reconnaissance, delivery, exploitation, and exfiltration were viable attack phases in this incident, while phases dependent on stronger monitoring and encryption controls would have been less viable if those protections were in place. Each vulnerability increased the impact of the next stage of the attack. This confirms that cybersecurity failures often happen through layered weaknesses instead of one technical failure. Strengthening only one control area would not have been enough without addressing the others.

2. Strategic Responses That Could Have Mitigated the BioGenX Breach

BioGenX had several strategic responses that could have prevented the breach, if they were implemented earlier. BioGenX had baseline security standards, but policy improvement and stronger enforcement would have made a major difference. The NIST framework explains organizations should "understand, assess, prioritize, and communicate cybersecurity risks and the actions that will manage those risks" (NIST, 2024). The breach shows that enforcement and follow-through were inconsistent, especially around legacy systems and sensitive data handling. The legacy systems and sensitive data handling issues were strong indicators of increased exposure risk. Stronger security policies should require regular system audits, mandatory encryption for research and patient data, and strict review of shared storage locations. Policies should require scheduled access reviews and configuration checks for older infrastructure. This helps prevent misconfigured server exposure and reduces the damage that can occur after credential theft. That type of structured policy and risk communication process would have reduced gaps that allowed this breach to grow.

Technology updates are another strategic response that would have mitigated the breach. Network monitoring and advanced intrusion detection were not properly in place. This allowed slow data exfiltration to continue without being detected. Effective defense requires integrating tools such as SIEM to aggregate and correlate logs, along with intrusion detection and prevention systems, and monitoring across endpoints, applications, and cloud environments (DNS Stuff, 2026). By upgrading to modern intrusion detection systems, centralized logging and endpoint detection tools would improve visibility across the network. Network segmentation and least privilege access controls would reduce how far attackers could move using stolen credentials. Regular audits and patch management help organizations close known vulnerabilities and improve defenses after incidents (DNS Stuff, 2026). Automated alerts for unusual outbound traffic and abnormal login behavior would make lateral movement easier to detect. Automated response tools can isolate endpoints or block malicious activity to shorten the time between detection and containment (DNS Stuff, 2026). With stronger detection technology in place, the command-and-control and exfiltration stages would have been less viable.

Another important mitigation strategy is to enhance employee training protocols. BioGenX provided general awareness training, but the spear phishing message still succeeded. Attackers view spear phishing messages as highly targeted and realistic attempts to gain access to the network. Employee training should be expanded into role-based and scenario-driven exercises. Active cyber learning should include cyber-attack simulations, interactive security training, and gamified training methods (Fortinet, 2025). Employees who work with research data or external communications should receive targeted phishing simulations and decision exercises. Training programs should include simulated spear phishing campaigns, reporting drills, and follow-up feedback, so employees learn to recognize and escalate suspicious messages. Secure organizations remain vulnerable to manipulation, noting that secure systems are still susceptible to social engineering attacks (Schneier, 2000). More frequent and measured training would reduce the likelihood of successful phishing clicks and make the delivery and exploitation stages less viable.

Overall, a combined strategy of stronger policy enforcement, modern detection technology, and deeper employee training would have significantly reduced the likelihood and impact of the BioGenX breach. Policy controls reduce exposure, technology controls increase detection, and training controls reduce human-factor risk. Addressing only one of these areas is not enough by itself. A layered strategy across governance, tools, and people makes later attack stages less viable and limits attacker success (NIST, 2024).

Exercise 3: Construct a phased attack decision matrix.

Attack Phase	Key Indicators	Validation Steps	Decision Trigger	Response Actions
Phishing Delivery	Suspicious journal email, malicious link	Check email headers, URL reputation, user confirmation	Phishing confirmed	Quarantine email, isolate endpoint, begin log review
Exploitation	Malware execution, credential harvesting	Endpoint scan, process review	Credential compromise likely	Force password reset, isolate host
Installation	Persistence artifact, new service/task	Check startup entries, Event 7045	Persistence confirmed	Remove malware, disable account
Lateral Movement	Unusual server access, privilege escalation	Review Event 4672, access logs	Internal spread detected	Disable account, segment network
Command & Control	Repeated outbound beacon traffic	Netflow + firewall logs	C2 traffic confirmed	Block outbound channel, escalate
Data Exfiltration	Large disguised outbound transfers	Traffic analysis, DLP alerts	Data theft likely	Contain systems, notify legal & IR lead

Response Strategy Trigger Matrix

Trigger	Decision	Action	Trigger
Credential compromise	Isolation	Disconnect endpoint	Credential compromise
Sensitive data access	Legal escalation	Notify compliance/ legal	Sensitive data access
Regulated data exposure	Regulatory reporting	Start breach notice timeline	Regulated data exposure
Containment started	Public communication	Activate comms lead	Containment started

A. Constructing a Phased Attack Decision Matrix for BioGenX Type Attacks

BioGenX phased attack decision matrix should be constructed as a structured guide that connects each attack phase to specific detection indicators, validation steps, and required response actions. The purpose of the matrix is to help incident response teams make consistent and evidence-based decisions. This will reduce reacting in an unstructured manner. BioGenX experienced an attack that moved from spear phishing to credential theft, lateral movement, and long-term data exfiltration. A decision matrix would allow responders to quickly determine what phase they are observing and what defensive action should be implemented next. This improves response speed, reduces confusion, and supports coordinated incident handling across technical and management teams.

The structure of the matrix should align with a recognized incident response lifecycle so that each response action follows an approved and repeatable guideline. This helps incident response teams make consistent decisions during fast-moving attacks like the BioGenX breach. Most IR plans can be summed up in 4 common steps: Preparation, Detection & Analysis, Containment & Eradication, and Post-Incident Activity (CrowdStrike, 2023). Before an incident occurs, the preparation stage builds the response team, required tools, authority structure, and decision rules so actions are clearly defined ahead of time. The detection and analysis stage centers on identifying indicators, confirming whether activity is malicious, documenting findings, and prioritizing incident severity. The containment and eradication stage involves isolating affected systems, removing attacker access, and restoring normal operations in a controlled manner. The post-incident activity stage captures lessons learned and drives policy updates and control improvements so the organization strengthens its defenses for future incidents. In a phased attack decision matrix, these four steps can be used as the response columns, while the cyberattack phases such as phishing delivery, exploitation, lateral movement, and exfiltration are used as the rows. When these lifecycle steps are built directly into the matrix, responders can quickly observe attacker behavior to the correct response stage and take the next approved action without delay.

To make the matrix effective for phased attacks, it should be built using the Cyber Kill Chain framework. Each attacker stage is matched with defender decisions and response triggers. This approach helps incident responders understand not only what the attacker is doing, but where defensive interruption is still possible. The framework is designed to support defensive identification and prevention efforts. The Cyber Kill Chain framework is part of the Intelligence Driven Defense model for the identification and prevention of cyber intrusions activity" (Lockheed Martin, n.d.). This identifies that each phase in the matrix should include what defenders should check, what evidence should be validated, and what control action should be taken. Early reconnaissance indicators should trigger validation checks and increased monitoring of exposed systems and user targeting patterns. Delivery and exploitation signals should lead to phishing verification steps and endpoint isolation decisions when malicious interaction is confirmed. Installation and lateral movement evidence should prompt account disablement, credential resets, and tighter internal access controls. Command-and-control or exfiltration behavior should result in outbound traffic blocking and rapid containment escalation. Understanding the phases makes it useful for decision matrices. Before the objective stage is reached, responders can block progress. When defender actions are mapped directly to each kill chain stage, the matrix becomes operational instead of theoretical and gives response teams step-by-step decision support during real incidents.

In practical use, the matrix would connect phishing delivery indicators to response actions such as email header analysis, user verification, and endpoint isolation when a malicious link is confirmed. Exploitation indicators such as malware execution or credential harvesting would trigger forced password resets, host containment, and rapid credential review. Lateral movement indicators such as unusual server access or shared drive enumeration would lead to account disablement and network segmentation controls to limit spread. Later-stage indicators such as suspicious outbound traffic or disguised data transfers would trigger containment and traffic blocking. The purpose of the containment phase is to halt the effects of an incident before it can cause further damage (CrowdStrike, 2023). Using a phased decision matrix built from both incident response stages and kill chain phases creates a repeatable and defensible response model for attacks similar to the BioGenX breach and supports faster, evidence-based incident handling decisions.

B. Decisions on Response Strategies: Isolation, Legal Notification, and Public Communication

Decisions on response strategies should be built directly into the phased attack decision matrix, so incident response teams can identify what action to take once specific indicators are confirmed. This prevents delays and reduces confusion during an active incident. Each response action should be tied to confirmed indicators in the matrix so responders follow predefined triggers instead of relying only on judgment. The most important early response decision is isolation of affected systems. When indicators such as phishing exploitation, malware execution, or credential theft are validated, the matrix should direct responders to immediately isolate the affected endpoint or server to prevent further spread. This action limits lateral movement and reduces additional data exposure while technical analysis continues. In the BioGenX scenario,

early isolation of the compromised workstation and rapid credential reset actions could have reduced attacker movement into shared file servers and sensitive data stores.

Containment actions are critical in every incident response process. It stops attacker activity early, reducing the total impact of a breach and protecting critical assets. Breach containment refers to the strategies and actions taken after a compromise is detected to limit the scope and prevent attackers from moving laterally within the network (Illumio, 2025). This supports building containment triggers directly into the phased attack decision matrix. When specific indicators like phishing exploitation, credential theft, or malware execution are confirmed, responders are directed to isolate the compromised endpoint or server immediately. Isolation and access control stop the attack from spreading, protect other systems, and limit data exposure while investigation and remediation continue. The breach containment framework highlights the importance of segmenting networks and restricting communications between systems so that even if one segment is compromised, the breach cannot easily propagate to others (Illumio, 2025). This is especially important in the BioGenX breach because isolating the infected workstation and segmenting access to the misconfigured file server containing research and patient data would reduce exposure. It reduced the attacker's ability to move laterally and copy sensitive information. Effective containment should also include preserving evidence and maintaining operational continuity where possible, so unaffected systems continue to function while the incident is contained (Illumio, 2025).

Legal notification decisions should also be built into the phased attack decision matrix and tied to confirmed investigation triggers instead of handled informally. When analysis confirms that regulated or sensitive data has been accessed, exposed, or exfiltrated, the matrix should automatically require escalation to legal and compliance teams. This ensures reporting timelines and regulatory obligations are not missed. Current breach law updates show that many states now enforce firm notification deadlines, with several major states requiring notice to affected individuals within about 30 days of confirmed breach discovery, and additional attorney general notification when large numbers of residents are impacted (2025 Breach Notification Law Update, 2025). These timelines are strict and vary by jurisdiction, so routing confirmed breach indicators directly to legal review helps ensure accurate classification of the incident and proper authority notification. BioGenX exposure of patient and clinical research data would trigger regulated data handling requirements. once data exposure is validated, legal review and regulatory notification steps should be activated. Embedding these legal escalation checkpoints into the decision matrix supports compliance, preserves evidence handling standards, and prevents delayed reporting errors.

Public communication decisions should be built into the phased attack decision matrix, so communication happens in a controlled and consistent way. Once containment actions begin and legal review confirms what data was affected, the matrix should trigger internal stakeholder notification, followed by approved external communication steps. Effective breach communication must be timely, consistent, and role-assigned to avoid confusion, panic, and misinformation (Chambers, 2026). Assigning a communications lead ensures that messages to customers, partners, regulators, and the media are accurate and aligned with investigation findings. Communication plans should define which channels are used and when updates are

released, so messaging stays coordinated across teams. BioGenX should use structured communication triggers to help protect organizational trust while still meeting transparency expectations tied to regulated data exposure. Connecting communication approvals to confirmed attack phases and legal clearance creates a repeatable and defensible response process that supports both compliance and reputation protection (Chambers, 2026).

Overall, embedding isolation, containment, legal notification, and communication decisions directly into the phased attack decision matrix creates a faster and more controlled response process. Instead of reacting case by case, responders follow predefined triggers based on confirmed attack indicators. This reduces response time, improves consistency, and supports both regulatory compliance and stakeholder trust. In incidents like the BioGenX breach, phase-based response decisions would significantly reduce spread, exposure, and reporting risk.

Exercise 4: Test a phased attack matrix.

Figure 1. Windows Event Viewer showing Security log overview

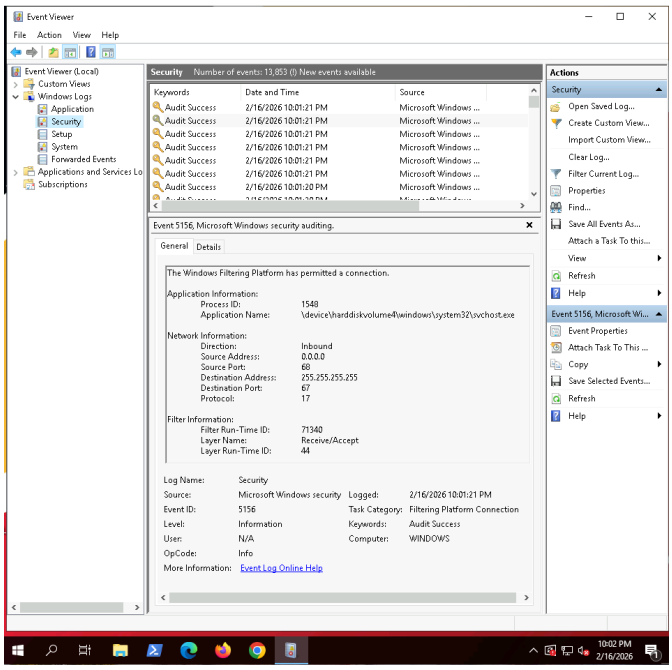
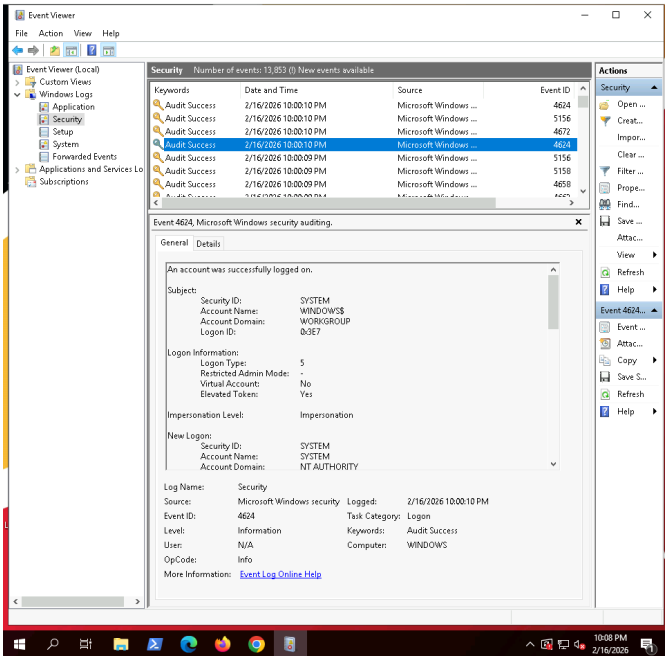


Figure 2. Event ID 4624 successful logon record in Security log

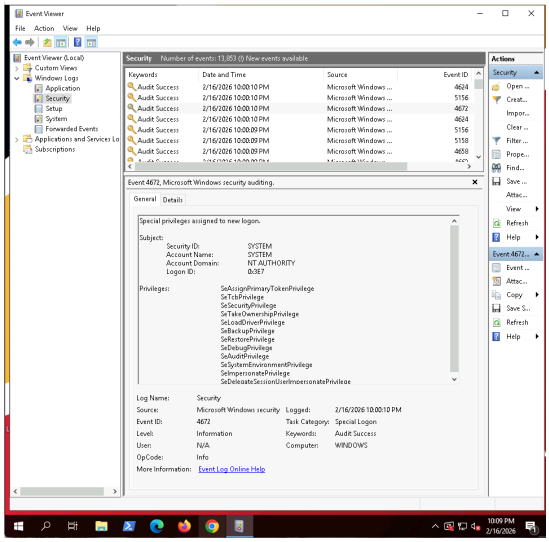


Event ID: 4624 | Log Name: Security | Source: Microsoft Windows security

Account Name: WINDOWS$ | Logon Type: 5 |Date and Time: 2/16/2026 10:00PM

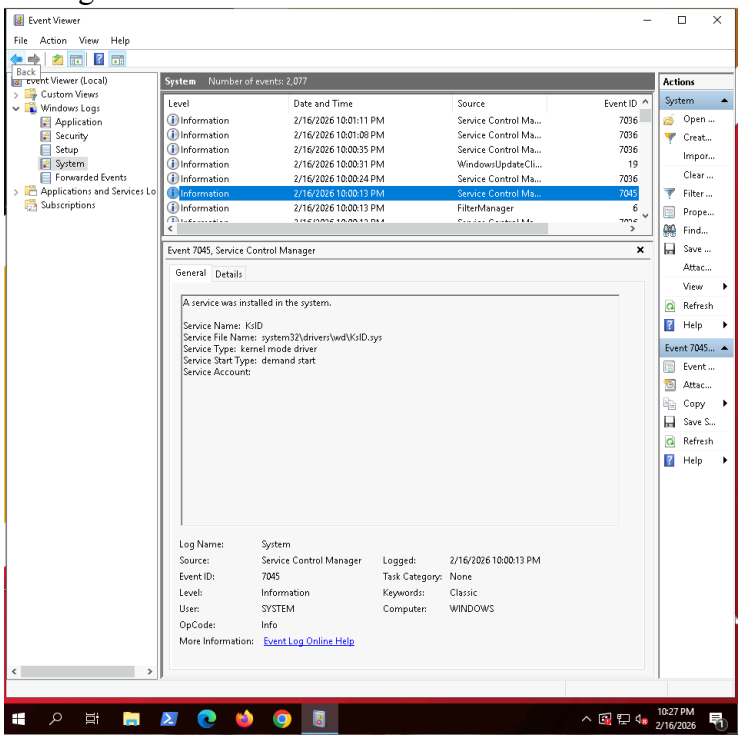
Computer: WINDOWS

Figure 3. Event ID 4672 privileged logon event



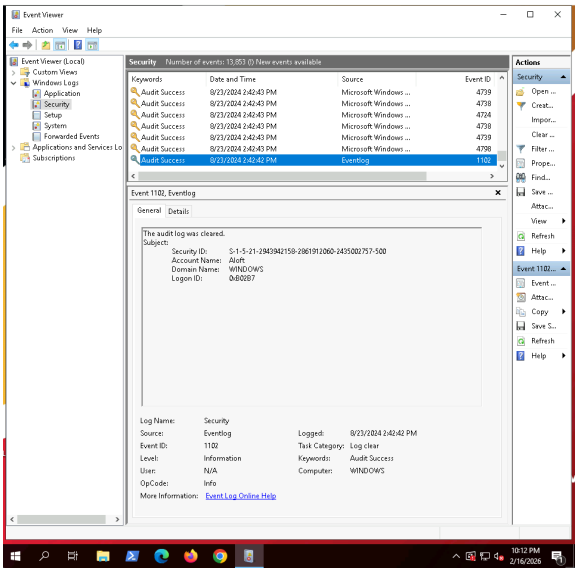
Event ID: 4672 | Log Name: Security | Privileged account logon indicator | Account: SYSTEM | Timestamp: 2/16/2026 10:00PM | Computer: WINDOWS

Figure 4. Event ID 7045 service installation event



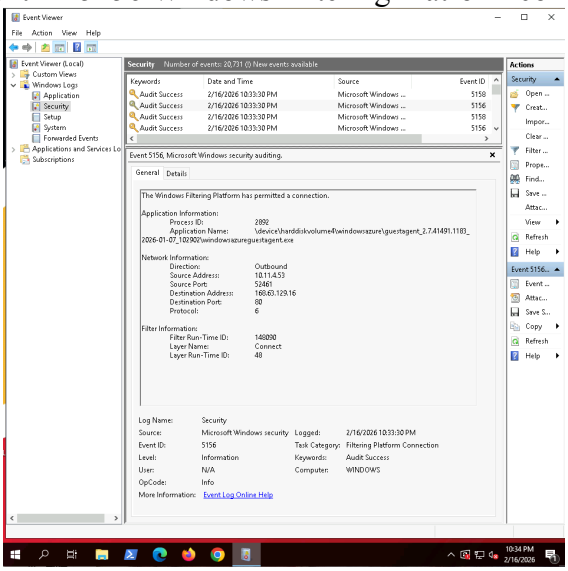
Event ID: 7045 | Log Name: System | New service installed entry | Service name: KsID | Installing account shown | Timestamp 2/16/2026 10:00PM

Figure 5. Event ID 1102 security audit log cleared



Event ID: 1102 | Log Name: Security | Action: Audit log cleared | Account Name: Aloft | Timestamp: 8/26/2024 2:42PM | Computer name: WINDOWS

Figure 6. Event ID 5156 Windows Filtering Platform connection event



1. How can you test your decision matrix from Exercise 3 using Windows Event Manager?

My phased attack decision matrix from Exercise 3 can be tested using Windows Event Viewer by matching real recorded log events to the attack phases and response triggers defined in the matrix. Windows Event Viewer allows me to validate whether the detection indicators and response actions listed appear in system evidence. Without using the matrix as a planning document alone. The lab states that security, application, policy, and access events on the Windows operating system are captured in event logs. This confirms that event logs provide the exact type of behavioral evidence needed to test each phase trigger in the matrix. These indicators can be observed and verified directly through system logging (Caseiro, 2019).

During the hands-on exercise, multiple security events were evidence of direct mapping to attack phases used in my matrix. For example, Event ID 4624 shows that an account successfully logged on, which supports detection triggers tied to initial access and valid credential use phases. Event ID 4672 shows that special privileges were assigned to a logon, which is a strong indicator to the privilege escalation phase and related decision points. The unit material explains that when Event ID 4624 is followed by Event ID 4672, it indicates a privileged account session, which should trigger elevated review and containment decisions in the matrix. Event ID 7045 shows that a new service was installed, which aligns with the persistence phase and should activate containment and investigation actions. Event ID 1102 shows that the audit log was cleared, which maps to the defense evasion phase and should trigger escalation and forensic preservation steps. These events demonstrate that the matrix can be tested by confirming that each phase-based trigger has a corresponding log indicator that defenders can monitor and validate.

This testing approach aligns with structured incident response guidance, where detection and analysis must be supported by observable system evidence before containment actions are taken. Incident response models emphasize that detection and analysis stages rely on verified indicators before moving to containment and eradication actions (CrowdStrike, 2023). By using Windows

Event Manager to observe real event IDs and match them to matrix triggers, the decision matrix becomes operational and testable instead of theoretical. It confirms that the defined response steps such as isolation, credential reset, privilege review, and containment escalation can be activated based on actual logged behavior rather than assumptions.

2. Based on the hands-on exercises, what events should you watch to prevent a similar incident from occurring in the future?

Based on the hands on Windows Event Viewer exercises, several specific event IDs should be continuously monitored because each event directly connects to attacker behavior such as unauthorized access, privilege escalation, persistence, and defense evasion. These events provide early warning indicators that map to the phased attack decision matrix and the attack lifecycle stages. Analyzing these logs helps defenders move from detection to response faster instead of only discovering an incident after damage has already occurred. The lab explains that security, application, policy, and access events on the Windows operating system are captured in event logs. This confirms that these logs are a primary evidence source for identifying suspicious system behavior before it becomes a larger breach (Windows Event Viewer Lab Guide, Unit Resource).

One important event to watch is Event ID 4624, which shows that an account was successfully logged on. This event is tied to valid credential use and possible initial access activity. The resource states, “This event generates when a logon session is created,” which makes it useful for tracking unexpected or unusual login behavior (Caseiro, 2019). When this event appears at unusual times or from unexpected systems, it should trigger review steps in the decision matrix. It is closely related to Event ID 4672, which shows privileged logons. When a standard logon event is followed by a privileged logon event, it indicates elevated account access. The lab guide explains, “When you see an Event ID 4624 followed by an Event ID 4672, that indicates that it’s a privileged account,” which supports using this as a privilege escalation detection trigger (Windows Event Viewer Lab Guide, Unit Resource). Monitoring these together helps detect misuse of administrator accounts.

Another key event to watch is Event ID 7045, which shows that a new service was installed. This is strongly connected to persistence techniques used by attackers. The lab explains, “Another interesting technique commonly used by attackers to maintain persistence and survive across reboots is the use of services,” and also states that “The Event ID 7045 will show up in Event Viewer when new services are created” (Windows Event Viewer Lab Guide, Unit Resource). Because malware often installs itself as a service, this event should trigger investigation and validation steps.

Event ID 1102 should also be watched closely because it indicates log clearing and possible defense evasion behavior. The lab states, “Event ID 1102 will be generated right after someone decides to clear the Security log,” which is a strong warning sign because attackers often clear logs to hide activity (Windows Event Viewer Lab Guide, Unit Resource). This event should trigger escalation and forensic preservation actions in the response matrix.

Finally, from the hands on results, Event ID 5156 is also useful because it shows permitted network connections through the Windows Filtering Platform. This helps identify unusual outbound connections and possible command and control style traffic patterns. Watching repeated or unexpected outbound connection events supports detection of data transfer and remote communication behavior tied to later attack phases.

Monitoring these event IDs together supports early detection across multiple attack phases including initial access, privilege escalation, persistence, command and control, and defense evasion. Using these logs as continuous monitoring points helps prevent a similar incident by allowing defenders to validate triggers in the phased attack decision matrix and respond before the attack fully progresses.

References:

- K, P. (2025, September 27). *Legacy systems and cybersecurity risks: what you need to know in 2025*. Legacy Software Modernization Company | ModLogix. https://modlogix.com/blog/legacy-systems-and-cybersecurity-risks-what-you-need-to-know-in-2025/

- Netskope. (2026, January 26). *What is a Cyber Security Kill Chain? - Netskope*. https://www.netskope.com/security-defined/cyber-security-kill-chain

- Human Factors and Information Security: individual, culture and security environment. (2010). In *DSTO-TR-2484*. https://apps.dtic.mil/sti/pdfs/ADA535944.pdf

- PricewaterhouseCoopers. (n.d.). *Data risk is everywhere: 5 steps to manage it*. PwC. https://www.pwc.com/us/en/services/consulting/cybersecurity-risk-regulatory/library/data-risk-is-everywhere.htm

- Member, S. (2026, January 9). *Cybersecurity Monitoring Best Practices: Building a Stronger Defense against modern Threats*. Software Reviews, Opinions, and Tips - DNSstuff. https://www.dnsstuff.com/cyber-security-monitoring-best-practices

- *Employee Cybersecurity Awareness Guide | Fortinet*. (n.d.). Fortinet. https://www.fortinet.com/resources/cyberglossary/cybersecurity-awareness

- *Cybersecurity 101: What is Breach Containment? | Illumio | Illumio*. (n.d.). https://www.illumio.com/cybersecurity-101/breach-containment

- *2025 Breach Notification Law Update | Perkins Coie*. (2025, October 15). https://perkinscoie.com/insights/update/2025-breach-notification-law-update

- *Getting Familiar with Logs and Windows Event Manager*. (n.d.). https://leocontent.umgc.edu/content/umuc/tgs/ctch/ctch635/2248/unit-6/getting-familiar-with-logs-and-windows-event-manager-.html